Incident Management and Response Policy

Transparency Hub Network Version: 1.0 **Effective Date:** March 5, 2026 **Last Updated:** March 5, 2026 **Owner:** Engineering Team **Classification:** Internal

---

1. Purpose

This policy establishes the framework for detecting, reporting, assessing, responding to, and recovering from security incidents and service disruptions affecting Transparency Hub Network. It ensures a consistent, efficient, and well-documented approach to incident management that minimizes impact on users, protects data, and maintains trust.

---

2. Scope

This policy applies to all incidents affecting:

- Application systems (frontend, backend, APIs)
- Infrastructure (Azure Functions, Static Web Apps, PostgreSQL, Blob Storage)
- Data (personal data, financial records, meeting recordings, credentials)
- Third-party integrations (Attendee.dev, Stripe, Paystack, Google, Zoom, Microsoft)
- Availability and performance of all services
- All personnel, contractors, and third parties with access to systems

---

3. Definitions

Term	Definition
Incident	Any event that compromises the confidentiality, integrity, or availability of information systems, data, or services
Security Incident	An incident involving unauthorized access, disclosure, modification, or destruction of data or systems
Service Disruption	An incident affecting the availability or performance of services without a security component
Data Breach	A security incident resulting in confirmed unauthorized access to or disclosure of personal data
Near Miss	An event that could have resulted in an incident but was detected and prevented before impact
Incident Owner	The individual assigned responsibility for managing the incident through resolution
Incident Commander	The Engineering Lead or designated senior engineer directing the response during major incidents

---

4. Incident Classification

4.1 Severity Levels

Severity	Code	Description	User Impact	Examples
Critical	P0	Active exploitation, confirmed data breach, or complete service outage	All users affected, data at risk	Database breach, production down, ransomware, credential leak at scale, payment data exposed
High	P1	Significant vulnerability exploited, major service degradation, or partial data exposure	Large subset of users affected	Auth bypass exploited, payment processing failure, single association data exposed, major feature outage
Medium	P2	Vulnerability with limited exploitation, minor service degradation, or contained security event	Limited users affected, workaround available	XSS exploited on non-critical page, elevated error rates, single component failure, phishing attempt targeting staff
Low	P3	Minor security finding, cosmetic issue, or brief service hiccup	Minimal or no user impact	Missing security header, brief latency spike (auto-recovered), failed brute force attempt (blocked), minor configuration drift
Informational	P4	Observation or near miss with no actual impact	No user impact	Suspicious but benign activity, vulnerability scan from external party, failed exploit attempt blocked by controls

4.2 Incident Categories

Category	Description	Examples
Unauthorized Access	Unauthorized entry to systems, accounts, or data	Account takeover, privilege escalation, unauthorized API access
Data Breach	Confirmed exposure or loss of personal/sensitive data	Database leak, credential exposure, unauthorized data download
Malware	Malicious software affecting systems	Ransomware, cryptominer, trojan (infrastructure-level, unlikely in PaaS)
Denial of Service	Service disruption through attack or overload	DDoS attack, application-layer flood, resource exhaustion
Application Vulnerability	Exploitation of software vulnerability	SQL injection, XSS, CSRF, API abuse
Configuration Error	Security misconfiguration leading to exposure	Open storage container, permissive CORS, disabled authentication
Third-Party Incident	Security incident at a vendor affecting our data or services	Attendee.dev breach, Stripe incident, Azure outage

Insider Threat	Malicious or negligent action by authorized personnel	Unauthorized data access, credential sharing, policy violation
Phishing / Social Engineering	Attempts to deceive personnel into compromising security	Phishing email, impersonation, credential harvesting
Service Outage	Unplanned service disruption (non-security)	Infrastructure failure, deployment error, dependency outage

---

5. Incident Response Team

5.1 Roles and Responsibilities

Role	Responsibility	When Activated
Incident Commander	Overall incident direction, decision-making, escalation, external communication	P0 and P1 incidents
Incident Owner	Day-to-day management of the incident, coordination, status updates	All incidents
Technical Lead	Root cause investigation, remediation implementation, technical decisions	P0, P1, and P2 incidents
Communications Lead	User notifications, stakeholder updates, regulatory notifications	P0 and P1 incidents, any data breach
On-Call Engineer	Initial detection response, triage, and containment	All incidents (24/7 rotation)

5.2 Escalation Matrix

Severity	First Responder	Escalation (if unresolved in SLA)	Final Escalation
P0 — Critical	On-Call Engineer → Incident Commander (immediate)	CTO / Co-Founder (1 hour)	All hands (2 hours)
P1 — High	On-Call Engineer → Engineering Lead (30 min)	Incident Commander (2 hours)	CTO / Co-Founder (4 hours)
P2 — Medium	Assigned Engineer	Engineering Lead (24 hours)	Incident Commander (48 hours)
P3 — Low	Assigned Engineer	Engineering Lead (1 week)	N/A
P4 — Info	Logged for review	N/A	N/A

5.3 Contact Information

Role	Primary Contact	Backup Contact

Incident Commander	Engineering Lead (direct message)	Co-Founder
On-Call Engineer	Rotation schedule (team calendar)	Engineering Lead
Communications	Engineering Lead	Co-Founder
Security Reports (External)	security@transparencyhubnetwork.ai	support@transparencyhubnetwork.ai

---

6. Incident Response Process

6.1 Phase 1: Detection and Reporting

Detection Sources:

Source	Type	Response
Azure Application Insights	Automated alerting	Alert triggers on-call notification
GitHub Security Alerts	CodeQL / Dependabot findings	Alert reviewed within acknowledgement SLA
OWASP ZAP Reports	Weekly DAST scan results	Findings triaged in next business day
User Reports	Email to support or security	Acknowledged within 4 hours
Third-Party Notification	Vendor security advisory	Assessed within 4 hours
Internal Discovery	Engineer identifies issue	Reported immediately via incident channel
External Researcher	Responsible disclosure	Acknowledged within 48 hours

Reporting Requirements:

All suspected incidents must be reported immediately with:

- Date and time of discovery
- Description of the event
- Systems/data believed to be affected
- How the incident was discovered
- Any actions already taken

Reporting Channels:

- **Internal:** Team group chat (immediate), followed by formal incident ticket
- **External (users):** support@transparencyhubnetwork.ai
- **External (researchers):** security@transparencyhubnetwork.ai

6.2 Phase 2: Triage and Assessment

Triage Steps (completed within acknowledgement SLA):

1. **Confirm** — Is this a real incident or false alarm?
2. **Classify** — Assign severity (P0–P4) and category
3. **Scope** — What systems, data, and users are affected?
4. **Assign** — Designate incident owner and activate response team as needed
5. **Log** — Create incident record with all known details

Assessment Questions:

- Is the incident ongoing or has it been contained?
- Is personal data affected? If so, what categories and how many individuals?
- Is the incident the result of an external attack or internal error?
- Are any third-party systems involved?
- Is there media or public awareness of the incident?
- Are there regulatory notification obligations?

6.3 Phase 3: Containment

Objective: Stop the incident from causing further damage while preserving evidence.

Short-Term Containment (immediate actions):

Action	When Used
Revoke compromised credentials	Credential exposure, account takeover
Block malicious IP addresses	Active attack, brute force, DDoS
Disable affected user accounts	Account compromise
Enable maintenance mode on affected services	Active exploitation, data exfiltration in progress
Revoke third-party API tokens	Third-party integration compromise
Apply emergency WAF rules	Application-layer attack
Scale down or isolate affected resources	Malware, lateral movement

Long-Term Containment:

Action	When Used
Patch vulnerable code and deploy	Application vulnerability exploited
Rotate all potentially affected secrets	Credential or key exposure
Update firewall and access rules	Unauthorized access pattern identified
Enable additional monitoring/logging	Ongoing investigation, suspected persistent threat
Disable affected feature behind feature flag	Feature-specific vulnerability

Evidence Preservation:

- Capture and preserve logs before rotation
- Screenshot or export relevant dashboards
- Document timeline of events as they unfold
- Do not modify affected systems beyond what is required for containment

6.4 Phase 4: Eradication

Objective: Identify and eliminate the root cause of the incident.

Eradication Steps:

1. **Root Cause Analysis** — Determine exactly how the incident occurred
2. **Vulnerability Remediation** — Fix the underlying vulnerability or misconfiguration
3. **Malware Removal** — Remove any malicious code or artifacts (if applicable)
4. **Verification** — Confirm the root cause has been fully addressed
5. **Testing** — Run SAST/DAST scans to verify the fix and check for related issues

Common Root Causes and Remediation:

Root Cause	Remediation
Code vulnerability (injection, XSS)	Patch code, add input validation, deploy fix
Misconfiguration	Correct configuration, add validation checks to CI/CD
Compromised credentials	Rotate all affected credentials, enable MFA, review access
Vulnerable dependency	Update dependency, apply override if upstream unavailable
Social engineering	Reset affected accounts, security awareness training
Third-party breach	Rotate integration credentials, assess data exposure, contact vendor

6.5 Phase 5: Recovery

Objective: Restore normal operations and confirm the incident is fully resolved.

Recovery Steps:

1. **Restore Services** — Bring affected systems back to normal operation
2. **Data Recovery** — Restore data from backups if integrity was compromised
3. **Validate Integrity** — Verify data accuracy and completeness post-recovery
4. **Monitor** — Implement enhanced monitoring for 72 hours post-recovery
5. **User Communication** — Notify users that services are restored (if disruption was visible)
6. **Remove Temporary Controls** — Remove emergency containment measures once permanent fix is confirmed

Recovery Objectives:

System	Recovery Time Objective (RTO)	Recovery Point Objective (RPO)
Frontend (Static Web App)	< 30 minutes	N/A (static assets from GitHub)
Backend API (Azure Functions)	< 1 hour	N/A (stateless, redeploy from GitHub)
Database (PostgreSQL)	< 4 hours	< 24 hours (daily backup)
Blob Storage (recordings, files)	< 2 hours	Near-zero (geo-redundant)
Payment processing	< 1 hour	N/A (managed by Stripe/Paystack)

6.6 Phase 6: Post-Incident Review

Objective: Learn from the incident and improve defenses.

Timeline: Post-incident review completed within **5 business days** of incident closure.

Review Agenda:

1. **Timeline Reconstruction** — Complete chronology from detection to resolution
2. **What Happened** — Factual description of the incident
3. **Root Cause** — Why did it happen? (use 5 Whys technique)
4. **What Went Well** — Effective response actions and controls
5. **What Could Be Improved** — Gaps in detection, response, or communication
6. **Action Items** — Specific, assigned, time-bound improvements
7. **Metrics** — Time to detect, time to contain, time to resolve, impact scope

Post-Incident Review Document:

Every P0, P1, and P2 incident produces a written post-incident review containing:

- Incident ID and classification
- Complete timeline
- Root cause analysis
- Impact assessment (systems, data, users affected)
- Response effectiveness evaluation
- Action items with owners and deadlines
- Preventive measures to avoid recurrence

Blameless Culture:

Post-incident reviews focus on **systemic improvements**, not individual blame. The goal is to strengthen processes, tools, and controls — not to punish individuals who made mistakes under pressure.

---

7. Communication Plan

7.1 Internal Communication

Audience	Channel	Frequency	Content
Incident Response Team	Group chat / video call	Real-time during active incident	Technical details, status, decisions
Engineering Team	Team channel	Every 2 hours during P0/P1, daily for P2	Status summary, impact, ETA
Leadership	Direct message / email	Immediately for P0, within 4 hours for P1	Impact summary, user exposure, ETA

7.2 External Communication — Users

Trigger	Channel	Timeline	Content
Service outage (visible to users)	Status page / email	Within 1 hour of detection	Acknowledgement, estimated resolution time
Service restored	Status page / email	Upon restoration	Confirmation, brief explanation
Data breach (user data affected)	Email to affected individuals	Within 72 hours	Nature of breach, data affected, actions to take, contact info

Security vulnerability (no data exposed)	No notification required	N/A	N/A

7.3 External Communication — Regulatory

Regulation	Authority	Notification Trigger	Timeline
NDPR / NDPA	National Information Technology Development Agency (NITDA)	Personal data breach affecting Nigerian data subjects	Within 72 hours
GDPR	Relevant EU/EEA Data Protection Authority	Personal data breach affecting EU/EEA data subjects	Within 72 hours
PCI DSS	Card brands (via Stripe/Paystack)	Payment data breach	Immediately (coordinated with payment processor)

7.4 Communication Templates

User Notification — Service Disruption:

> *Subject: Service Disruption — Transparency Hub Network*
>
> *We are currently experiencing a disruption affecting [describe affected services]. Our team is actively working to resolve the issue. We expect services to be restored by [estimated time].*
>
> *We apologize for the inconvenience. For updates, please contact support@transparencyhubnetwork.ai.*

User Notification — Data Breach:

> *Subject: Important Security Notice — Transparency Hub Network*
>
> *We are writing to inform you of a security incident that may have affected your personal data. On [date], we detected [brief description of what happened].*
>
> ***What data was affected:*** *[Categories of data]* ***What we have done:*** *[Actions taken to contain and remediate]* ***What you should do:*** *[Recommended actions — e.g., change password, monitor accounts]*
>
> *We take this matter seriously and have implemented additional security measures to prevent future incidents. If you have questions, please contact support@transparencyhubnetwork.ai.*

---

8. Incident Response Playbooks

8.1 Playbook: Credential Exposure

Step	Action	Owner
1	Identify which credentials were exposed and where	On-Call Engineer
2	Immediately rotate all exposed credentials	On-Call Engineer
3	Review audit logs for unauthorized use of exposed credentials	Technical Lead
4	If credentials were used: escalate to P0/P1, assess data impact	Incident Commander

5	Scan all repositories for additional exposed secrets	Technical Lead
6	Update secret scanning rules to prevent recurrence	Technical Lead
7	Notify affected third parties if their credentials were involved	Communications Lead

8.2 Playbook: Unauthorized Data Access

Step	Action	Owner
1	Confirm unauthorized access and identify affected data	On-Call Engineer
2	Revoke the unauthorized access immediately	On-Call Engineer
3	Preserve access logs and evidence	Technical Lead
4	Determine scope: which users, which data, how long	Technical Lead
5	Assess whether personal data was exposed (data breach determination)	Incident Commander
6	If data breach: initiate 72-hour notification process	Communications Lead
7	Fix the access control vulnerability	Technical Lead
8	Conduct access review of related systems	Incident Owner

8.3 Playbook: DDoS / Service Disruption

Step	Action	Owner
1	Confirm service disruption and identify affected components	On-Call Engineer
2	Activate Azure DDoS protection / scaling if applicable	On-Call Engineer
3	Implement rate limiting / IP blocking for malicious traffic	Technical Lead
4	Post status update to users if disruption exceeds 15 minutes	Communications Lead
5	Monitor traffic patterns and adjust defenses	Technical Lead
6	Restore normal operations once attack subsides	On-Call Engineer
7	Implement long-term mitigations (enhanced rate limiting, WAF rules)	Technical Lead

8.4 Playbook: Third-Party Vendor Incident

Step	Action	Owner
1	Assess vendor notification for impact on our data/services	On-Call Engineer
2	Rotate all credentials and tokens for the affected vendor	On-Call Engineer
3	Determine if our users' data was exposed through the vendor	Technical Lead
4	If user data affected: treat as data breach, initiate notification	Incident Commander
5	Implement temporary mitigations (disable integration if necessary)	Technical Lead

6	Request detailed incident report from vendor	Incident Owner
7	Evaluate continued use of vendor based on their response	Engineering Lead

8.5 Playbook: Application Vulnerability Exploitation

Step	Action	Owner
1	Confirm exploitation and identify the vulnerability	On-Call Engineer
2	Disable affected feature via feature flag or emergency patch	On-Call Engineer
3	Analyze attack payloads and access logs	Technical Lead
4	Determine if data was accessed or modified	Technical Lead
5	Develop and test permanent fix	Technical Lead
6	Deploy fix, run SAST/DAST verification	Technical Lead
7	Restore disabled feature	On-Call Engineer
8	Add detection rules for the attack pattern	Technical Lead

---

9. Incident Metrics and KPIs

9.1 Key Performance Indicators

Metric	Definition	Target
Mean Time to Detect (MTTD)	Time from incident occurrence to detection	P0: < 15 min, P1: < 1 hour
Mean Time to Acknowledge (MTTA)	Time from detection to triage completion	P0: < 1 hour, P1: < 4 hours
Mean Time to Contain (MTTC)	Time from detection to containment	P0: < 4 hours, P1: < 8 hours
Mean Time to Resolve (MTTR)	Time from detection to full resolution	P0: < 24 hours, P1: < 72 hours
Incident Recurrence Rate	Percentage of incidents with same root cause	< 5%
SLA Compliance	Percentage of incidents resolved within SLA	> 95%
Post-Incident Review Completion	Percentage of P0-P2 incidents with completed review	100%
Action Item Completion	Percentage of post-incident actions completed on time	> 90%

9.2 Reporting

Report	Audience	Frequency
Incident summary	Engineering team	After each P0-P2 incident
Monthly incident report	Leadership	Monthly
Quarterly incident trends	Full team	Quarterly
Annual incident review	Leadership + stakeholders	Annually

---

10. Testing and Exercises

10.1 Tabletop Exercises

- Conducted **quarterly** to test incident response procedures
- Scenarios cover different incident categories and severity levels
- All incident response team members participate
- Findings used to update playbooks and procedures

10.2 Simulation Exercises

- Conducted **annually** to test full incident response capability
- Simulated incident injected into systems (in staging environment)
- End-to-end response tested: detection → containment → eradication → recovery
- Communication processes tested including user notification drafting

10.3 Backup Recovery Testing

- Database restoration tested **quarterly** from automated backups
- Recovery time measured against RTO targets
- Results documented and gaps addressed

10.4 Exercise Log

All exercises are recorded with:

- Date and type of exercise
- Scenario description
- Participants
- Findings and lessons learned
- Action items for improvement

---

11. Continuous Improvement

11.1 Improvement Sources

Source	Input	Action
Post-incident reviews	Root cause analysis, lessons learned	Update controls, playbooks, detection rules
Tabletop exercises	Procedural gaps, communication issues	Update response procedures

Industry threat intelligence	Emerging attack vectors	Update detection and defenses
Regulatory changes	New compliance requirements	Update notification procedures
Tool evaluations	Better detection/response capabilities	Evaluate and adopt new tools

11.2 Policy Updates

This policy is updated when:

- A post-incident review identifies procedural gaps
- A tabletop exercise reveals inadequate procedures
- Organizational changes affect the incident response team
- Regulatory requirements change
- New systems or services are introduced
- At minimum, reviewed quarterly

---

12. Legal and Regulatory Considerations

12.1 Evidence Handling

- All incident evidence is preserved for potential legal proceedings
- Chain of custody maintained for digital evidence
- Evidence stored securely with access restricted to incident response team
- Evidence retention: minimum 3 years after incident closure

12.2 Law Enforcement

- Law enforcement is contacted for incidents involving criminal activity (e.g., extortion, fraud)
- Engineering Lead authorizes law enforcement contact
- Legal counsel consulted before sharing information with law enforcement

12.3 Insurance

- Cyber insurance policy reviewed annually for adequate coverage
- Insurance carrier notified promptly for incidents that may result in claims
- Policy requirements for incident response followed (notification timelines, approved vendors)

---

13. Related Documents

Document	Description
Security Policy	Comprehensive security controls and practices
Vulnerability Management Policy	Vulnerability identification and remediation
Data Retention and Protection Policy	Data handling, retention, and disposal
SSDLC	Secure Software Development Lifecycle
SAST & DAST	Application security testing documentation

Privacy Policy	Public-facing privacy notice
Terms of Service	User agreement

---

14. Document Control

Version	Date	Author	Changes
1.0	2026-03-05	Engineering Team	Initial version

This policy is reviewed and updated quarterly, or immediately following a significant incident, exercise finding, or regulatory change.

For questions about this policy, contact: support@transparencyhubnetwork.ai To report a security incident: security@transparencyhubnetwork.ai